The SOC2 For Solo Founders Playbook

A 24-page field guide to getting SOC2 Type 1 in 90 days as a solo founder, without quitting your roadmap, hiring a CISO, or selling your equity to a security consultancy.

Who this is for: founders of B2B SaaS startups whose first enterprise prospect just asked for "your SOC2 letter" and you have 90 days to ship one. You've heard it costs $50k+ and 6 months. Both are wrong if you do it right.

What this is not: a deep dive into the 64 SOC2 Trust Service Criteria. This is the minimum viable compliance program that holds up to a real audit and lets you close enterprise deals.

Chapter 1 -- Why SOC2 is a sales tool, not a tax

Most founders treat SOC2 like an obligation: something bigcos do to slow down your sales cycle. The opposite is true. Done well, SOC2 is the reason your enterprise deal closes in 60 days instead of 9 months. Done badly, it is the reason your seed round doesn't convert to a Series A when the lead investor asks for the security questionnaire and you have nothing to show.

The reason: every enterprise buyer, every Series A+ term sheet, and every procurement team above 50 employees now asks for SOC2. They want a letter. They want a report. They want to know when your last audit was. If your answer is "we're working on it," you lose the deal. If your answer is "here's our Type 1 report from Q3," you close.

The hard part is that this evidence is hard to fake. You either have the discipline to build security into the development loop, or you don't, and your enterprise pipeline will reflect that within two quarters.

This playbook is about the discipline. Specifically, the minimum viable version of it that holds up to a real audit and closes deals. The framework underneath is SOC2 Type 1 (the version you should get first) covering the 5 Trust Service Categories: Security, Availability, Processing Integrity, Confidentiality, and Privacy. You'll cover Security (mandatory) and Availability (what your customers actually care about). Skip the other three for now -- they only matter for specific industries.

By the end of this book, you will have a 90-day plan to ship a SOC2-ready program that closes your first enterprise deal.

Chapter 2 -- The five controls every solo founder must have

You need five working controls. Not 50. Five. Every SOC2 audit, every enterprise security questionnaire, and every procurement call will pull from these same five policies. Build them once, keep them current, and reuse them forever.

1. Access control. Who can access what, when, and how is it revoked. The minimum: SSO on every production system, MFA on every account, offboarding checklist that disables accounts within 24 hours of termination. Use Google Workspace or Okta for SSO. Don't roll your own. Auditors will dig into your offboarding process more than anything else -- that's where the data breaches happen.

2. Change management. Every code change is reviewed, tested, and deployed through a documented process. The minimum: GitHub PRs with at least one approval, automated tests passing, and a CHANGELOG entry per release. Auditors want to see three specific things: the PR, the test results, and who approved the merge. If you can't produce these for a random commit from 6 months ago, you don't have change management.

3. Incident response. A written plan for what to do when something goes wrong: data breach, ransomware, customer data leak. The minimum: a one-page runbook (page 23 has the template), a designated incident commander (probably you), a 72-hour customer notification commitment, and a post-mortem template. Auditors will ask you to walk through a hypothetical incident. If you can't recite the runbook from memory, you don't have an incident response plan.

4. Vendor management. A list of every third-party service that touches customer data, plus the security review you did before using it. The minimum: a spreadsheet with vendor name, data they access, SOC2 or equivalent status, and review date. AWS, Stripe, OpenAI, your analytics tool, your email tool -- that's typically 8-15 vendors. Auditors want to see you evaluated each one before integrating.

5. Encryption + backup. Customer data is encrypted at rest and in transit. Backups are tested monthly. The minimum: TLS everywhere (one line in your load balancer config), database encryption at rest (one checkbox in your DB provider), automated daily backups with a monthly restore drill. Auditors will ask for the last restore drill date. If it's "I don't know," you don't have backup testing.

You can have all five in two weeks. Most startups take 3 months because they overthink the format. Use the templates in Appendix A. Done is better than perfect.

Chapter 3 -- The 90-day plan to ship SOC2 Type 1

The plan is deliberately small. If you can't do 90 days of this, you can't do SOC2 at all and should not be selling to enterprises.

Days 1-14 -- Pick the auditor and the platform. The auditor matters more than the platform. For a solo founder doing Type 1, you want one of: Vanta, Drata, Secureframe, or Sprinto. They bundle the policy templates, the evidence collection, and the audit in one. Vanta is the market leader. Cost: $7-15k/year. The auditor: pick one Vanta recommends. Cost: $8-15k for Type 1. Total: $15-30k. Pay it. It's cheaper than losing one enterprise deal.

Days 15-30 -- Write the five policies. Use the templates in your compliance platform. Don't write from scratch. The five policies: Information Security, Access Control, Change Management, Incident Response, Vendor Management. Each is 2-4 pages. Don't agonize. Auditors want to see they exist, not that they're

pretty.

Days 31-60 -- Turn on the controls. This is the hardest part because it's where the discipline shows. Turn on SSO. Turn on MFA. Connect your code repo to the evidence collector. Connect your AWS. Connect your HR system. Connect your ticketing system. Every integration adds evidence automatically. The goal by day 60 is "all 5 controls are on and producing evidence continuously."

Days 61-75 -- Evidence review. Your compliance platform shows you which controls have gaps. Fix them. Common gaps: missing background checks (use Checkr, $30/employee), missing security training (use the platform's free training module), missing vendor reviews (spend one afternoon filling in the vendor spreadsheet).

Days 76-90 -- Audit. The auditor reviews your evidence, runs sampling tests, and issues the Type 1 report. There will be findings. Don't panic. Type 1 audits always have findings. The report is still issued. Fix the findings before Type 2 next year.

The output of day 90 is a real SOC2 Type 1 report. It will not be perfect. It will be enough.

Chapter 4 -- The five things that will get you in trouble

These are the patterns I've seen get solo founders into actual trouble during a SOC2 audit. They are all preventable.

1. "We'll write the policies later." Every auditor finds this. The fix: write the policies in week 2 using the platform templates. They don't need to be custom. They need to exist before the audit starts.

2. No offboarding checklist. Auditors dig into terminated employees. If an employee left 8 months ago and their AWS access is still active, that's a finding. The fix: HR sends a Slack message to IT on the day of termination, and IT has a checklist (disable SSO, rotate keys, remove from repos, remove from AWS, remove from vendor consoles). Takes 30 minutes per termination.

3. No tested backups. "We have backups" is not the same as "we tested restoring from backups." The fix: a monthly cron job that restores yesterday's backup to a test environment, and an email to the team saying "backup restored successfully." Keep the emails. Auditors love them.

4. Vendor reviews that don't exist. If you integrate with 15 vendors and have 0 documented reviews, that's 15 findings. The fix: spend one afternoon filling in the vendor spreadsheet. For each vendor, the "review" can be one sentence: "Stripe -- SOC2 Type 2, last reviewed 2026-01-15." Auditors accept that.

5. Penetration tests skipped. Type 1 doesn't require a pen test. Type 2 does. So you have a year to do one. But don't wait -- book it now, do it in month 6. A basic pen test is $3-8k. The Vanta platform can recommend one. Don't skip it; auditors compare you to peers, and skipping is a red flag.

Chapter 5 -- The program that compounds after the first audit

After the 90-day plan, you have a SOC2 Type 1 report. The next 12 months are about making it a habit, not a one-time project, and upgrading to Type 2.

Quarter 1 post-audit -- Embed the controls. Add "evidence updated" as a checkbox in your quarterly review. Add the offboarding checklist to your HR workflow. Add the vendor review to your procurement workflow. None of this is hard. It's the same control, surfaced at the moment it's needed.

Quarter 2 -- Quarterly access reviews. Review every employee's access to every system. Disable what they don't need. Auditors will sample this for Type 2 and find the dormant accounts you forgot. The fix: a quarterly 90-minute meeting with HR and IT to walk the list.

Quarter 3 -- Penetration test. Do it now if you didn't in Q1. The report is required for Type 2. Cost: $3-8k. Value: 10x when an enterprise asks "when was your last pen test?"

Quarter 4 -- Type 2 prep. Type 2 is the same controls, but audited over 6-12 months instead of a point in time. Start collecting evidence of operational excellence. By the time you book Type 2, you want a full year of quarterly access reviews, monthly backup tests, and 12+ months of incident-free operations.

By month 12 you have a SOC2 Type 2 report that holds up to any enterprise security review, any Series A diligence call, and any government RFP. The cost in time was 90 days of focused work in the first quarter and 2-3 hours per month after. The cost in cash was $20-40k. The cost in deals lost from not having it is the part that motivated you to read this book in the first place.

Appendix A -- Templates

- **Information Security Policy (template, ~3 pages):** Mission statement, scope, 10-15 control statements, review cadence.
- **Access Control Policy:** SSO requirement, MFA requirement, offboarding process, quarterly review.
- **Change Management Policy:** PR review, testing, deployment, rollback, audit log retention.
- **Incident Response Plan (the 1-pager):** Detection -> Containment -> Eradication -> Recovery -> Post-mortem. Include contact info.
- **Vendor Management Policy:** Vendor inventory, risk tiering, review checklist, ongoing monitoring.

Appendix B -- The 90-day calendar

Week	Action	Owner
1	Pick platform (Vanta/Drata) + auditor	Founder
2	Sign contracts, kick off onboarding	Founder
3-4	Write 5 policies from templates	Founder
5-6	Integrate 5 systems (SSO, code repo, AWS, HR, ticketing)	Engineer + Founder

| 7-8 | Fill vendor reviews, run background checks | Founder |

| 9 | Run first internal audit (platform does this) | Founder |

| 10-12 | External audit, address findings | Auditor + Founder |

Appendix C -- Resources

- Vanta (`vanta.com`) -- market leader, $7-15k/yr
- Drata (`drata.com`) -- close second
- AICPA SOC2 overview (`aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2`)
- The "SOC2 for SaaS" guide by Christina Cacioppo (`github.com/typelevel/scala`) -- 60 pages, very practical
- Tugboat Logic (now part of OneTrust) -- alternative platform
- The Vanta SOC2 checklist (`vanta.com/products/soc-2`) -- public, no signup

Conclusion

You don't need a CISO to ship SOC2. You need five policies, 90 days, and the discipline to keep them current. The five controls. The five policies. The platform. The auditor. The rest is repetition.

If you ship the 90-day plan and the controls fall apart within 6 months, you didn't really ship a security program -- you shipped a project. The program is the habit. The habit is one quarterly review meeting and one monthly backup test.

Either way, SOC2 is now a buyer expectation, not a nice-to-have. The startups that close enterprise deals in 2026 and beyond are the ones whose founders read a playbook like this on a Tuesday and shipped the report by Friday.

Go ship it.